

Akte Lahnwerke Maschinenbau AG

- Slack, AirTags und IT-Sicherheitslage

Inhaltsverzeichnis

Teil	Inhalt
Teil 1	Aktenstücke (6)
Teil 2	E-Mails (3)
Teil 3	CSV-Tabellen (3)
Teil 4	Excel-Tabellen (1)
Teil 5	Word-Dokumente (3)
Teil 6	Bildanlagen und Screenshots (2)
Teil 7	PDF-Anhänge (Originaldokumente) (6)

Aktenstücke

Datei: 01-mandatsnotiz-und-arbeitsauftrag.md

Mandatsnotiz

Lahnwerke Maschinenbau AG rollt Slack aus, verfolgt LKW-Werkzeugcontainer mit AirTags, betreibt MDM auf Firmenhandys und hat nach einem Lieferanten-VPN-Vorfall Zweifel an NIS-2-/BSI-Reife.

Beteiligte: Geschäftsleitung, Rechtsabteilung, operative Fachabteilungen, externe IT/Compliance-Berater und mehrere Personen mit eigenen Interessen. Die Akte ist bewusst unaufgeräumt: manche Unterlagen widersprechen sich, Zahlenstände weichen ab und einzelne Dokumente wirken bereits überholt.

Arbeitsziel heute: zuerst sortieren, dann keine vorschnelle Rechtsmeinung ausgeben. Jede harte Aussage soll auf ein konkretes Aktenstück oder eine frei prüfbare Quelle zurückgeführt werden.

Datei: 02-zeitstrahl-und-fristen.md

Zeitstrahl

- 04.02.2026: erster interner Hinweis auf Lücken und unklare Verantwortlichkeiten.
- 18.03.2026: Fachbereich bittet um schnelle Freigabe, obwohl Legal noch keine Unterlagen gesehen hat.
- 29.04.2026: externe Partei fragt nach Nachweisen und Fristen.
- 13.05.2026: Geschäftsleitung will eine entscheidungsfähige Vorlage bis Freitagmittag.
- 26.05.2026: mehrere neue Dateien kommen unsortiert per E-Mail und Chat.

Datei: 03-prueffragen-fuer-erstgespraech.md

Prüffragen

1. Welche Entscheidung soll am Ende unterschrieben werden?
2. Welche Unterlagen fehlen noch wirklich?
3. Welche technische oder wirtschaftliche Tatsache darf nicht einfach unterstellt werden?
4. Wer kann verbindlich Auskunft geben?
5. Welche Rechtsquelle muss live geprüft werden?

Datei: 16-krisenstabs-runbook-auszug.md

Krisenstab

Rollen: CEO, CISO, Legal, Datenschutz, HR, Kommunikation, IT-Betrieb, externer Forensiker. Offene Lücke: Notfalltelefonliste liegt nur in SharePoint. Bei M365-Ausfall nicht verfügbar.

Datei: 18-java-pki-zertifikatsnotiz.md

Java / PKI

Build-Signing-Zertifikat läuft am 09.07.2026 ab. Keystore liegt laut Engineering noch auf einem Runner-Volume. HSM-Einsatz war budgetiert, aber nie beauftragt. Release 4.8 hängt am Zertifikat.

Datei: 21-offene-punkte-und-lueckenliste.md

Offene Punkte

- Originalquellen und aktuelle Gesetzesfassungen live prüfen.
- Fehlende technische oder kaufmännische Nachweise nicht durch Vermutungen ersetzen.
- Widersprüche zwischen E-Mail, Tabelle und Vertrag markieren.
- Für harte Aussagen immer Aktenfundstelle nennen.

E-Mails

Datei: 09-email-ciso-an-legal.eml

Von	ciso@lahnwerke.example
An	legal@lahnwerke.example
Datum	Tue, 26 May 2026 07:42:00 +0000
Betreff	Freigabe Slack / NIS2 / AirTags - brauche belastbare Linie

Guten Morgen,

der Vorstand will am Freitag entscheiden. Ich möchte nicht nur die üblichen Zertifikate zeigen, sondern eine echte Linie: NIS-2/BSIG, BSI-Grundschutz, Slack, AirTags, MDM, Java-Zertifikate und Incident-Meldeweg. Bitte auch aufnehmen, wo wir noch keine Nachweise haben.

Viele Grüße
Marlene

Datei: 10-email-einkauf-supplier-remote.eml

Von	service@frankenturm-automation.example
An	einkauf@lahnwerke.example
Datum	Sat, 23 May 2026 14:06:00 +0000
Betreff	Dauerhafter VPN-Tunnel für Pressenwartung

Hallo,

für die neue Pressenlinie benötigen wir dauerhaft offenen VPN-Zugang aus unserem Servicecenter. Unser Standardvertrag sieht keine Session-Aufzeichnung vor. Ohne Zugriff verlieren Sie die Reaktionszeit im SLA.

Gruß
K. Rehbaum

Datei: 15-betriebsrat-mdm-airtags.eml

Von	br@lahnwerke.example
An	vorstand@lahnwerke.example
Datum	Sun, 24 May 2026 16:22:00 +0000
Betreff	MDM, AirTags und neue Logging-Regeln

Sehr geehrte Damen und Herren,

wir verlangen Beteiligung vor Einführung weiterer MDM-, Tracking- und Loggingmaßnahmen. Uns liegt eine Liste von acht Fahrzeugen mit AirTags vor. Bitte stoppen Sie den Rollout bis zur Klärung der Zwecke, Zugriffsrechte und Löschfristen.

Betriebsrat

CSV-Tabellen

Datei: 08-asset-inventar-auszug.csv

Asset	Typ	Owner	Kritikalität	Nachweis
SAP S4	ERP	IT Betrieb	hoch	CMDB
LKW AirTags	Tracker	Logistik	mittel	nur Excel
Code Signing CA	PKI	Engineering	hoch	unvollständig
Slack	SaaS	IT Collaboration	hoch	Security Memo

Datei: 19-lieferanten-questionnaire.csv

Frage	Antwort Lieferant	Nachweis	Bewertung
MFA Fernwartung	ja	Screenshot Admin Portal	gelb
Session Recording	nein	Standardvertrag	rot
Incidentmeldung 24h	unklar	SLA	rot
Subunternehmer	Polen/Indien	Liste	gelb

Datei: 22-anlagenindex.csv

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
01-mandatsnotiz-und-arbeitsauftrag.md	MD	mittel	Erste Lage, Personen, Ziel und offene Fragen
02-zeitstrahl-und-fristen.md	MD	mittel	Chronologie mit Entscheidungs- und Eskalationspunkten
03-prueffragen-fuer-erstgesprach.md	MD	mittel	Katalog für das erste strukturierte Gespräch
04-vorstandsvorlage-cyber-roadmap.docx	DOCX	hoch	Entwurf Vorstandsvorlage zur Cyber-Roadmap
05-cyber-risk-register.xlsx	XLSX	hoch	Risikoregister mit Maßnahmen, Ownern und Fristen
06-nis2-betroffenheitsvermerk.pdf	PDF	hoch	Vermerk zur vorläufigen NIS-2-/BSIG-Betroffenheit
07-slack-cloud-security-memo.pdf	PDF	hoch	Cloud-/SaaS-Prüfung Slack-Rollout
08-asset-inventar-auszug.csv	CSV	mittel	Asset-Inventar mit Lücken
09-email-ciso-an-legal.eml	EML	hoch	CISO fragt Legal nach Leitungsvorlage
10-email-einkauf-supplier-remote.eml	EML	mittel	Lieferant bittet um dauerhafte Fernwartung
11-backup-restore-protokoll.pdf	PDF	mittel	Restore-Test mit erkennbaren Lücken
12-whatsapp-it-legal.jpg	JPG	mittel	Chat-Screenshot IT/Legal mit operativer Dringlichkeit

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
13-screenshot-siem-alerts.jpg	JPG	mittel	SIEM-/SOC-Screenshot als Bilddatei
14-policy-entwurf-screenshots-und-chat.docx	DOCX	mittel	Policy-Entwurf Screenshots und Chat
15-betriebsrat-mdm-airtags.eml	EML	mittel	Betriebsrat verlangt Beteiligung
16-krisenstabs-runbook-auszug.md	MD	mittel	Runbook-Auszug Krisenstab
17-cloud-provider-c5-luecken.pdf	PDF	mittel	Cloud-Provider-Prüfung C5/Region/Exit
18-java-pki-zertifikatsnotiz.md	MD	mittel	Notiz zu Java-Code-Signing und PKI
19-lieferanten-questionnaire.csv	CSV	mittel	Supplier-Security-Fragebogen
20-board-briefing-draft.pdf	PDF	mittel	Board-Briefing als Arbeitsstand
21-offene-punkte-und-lueckenliste.md	MD	mittel	Offene Punkte und Lückenliste
22-anlagenindex.csv	CSV	mittel	Anlagenindex

Excel-Tabellen

Datei: 05-cyber-risk-register.xlsx

Tabellenblatt: Risiken

ID	Risiko	Asset	Impact	Kontrolle	Owner	Frist	Status
R-01	Ransomware verschlüsselt ERP und Produktionsplanung	SAP + Fileserver	sehr hoch	Immutable Backup + Restore-Test	CISO	2026-06-21	gelb
R-02	Slack-Screenshots enthalten Kundendaten und VPN-Token	Slack Enterprise Grid	hoch	DLP + Screenshot Policy	Legal/IT	2026-06-12	rot
R-03	AirTags an LKW erzeugen Beschäftigten Daten ohne BV	Fuhrpark	mittel	Betriebsvereinbarung + Zweckbindung	HR	2026-06-30	gelb
R-04	Java-Code-Signing-Zertifikat läuft im Juli ab	Build Pipeline	hoch	PKI-Inventar + HSM-Prüfung	Engineering	2026-06-10	rot

Tabellenblatt: Nachweise

Nachweis	Akte	Fehlt
Restore-Test	11-backup-restore-protokoll.pdf	vollständiger AD-Recovery-Test
Betriebsrat	15-betriebsrat-mdm-airtags.eml	Beschlussfassung
Cloud C5	07-slack-cloud-security-memo.pdf	Subprozessorenliste

Word-Dokumente

Datei: 04-vorstandsvorlage-cyber-roadmap.docx

Vorstandsvorlage Cyber-Roadmap

Die Lahnwerke Maschinenbau AG betreibt Produktions-IT, ein europaweites Ersatzteillager, Telematik in 88 LKW und mehrere Cloud-SaaS-Dienste. Die Vorstandsvorlage soll keine bloße Zertifikatsliste werden, sondern die Entscheidung über Budget, Verantwortlichkeit und Nachweise ermöglichen.

Der CISO hält eine NIS-2-Betroffenheit für wahrscheinlich, aber die Sektorzuordnung ist nicht sauber dokumentiert. Einkauf und Logistik möchten Slack und AirTags sofort freigeben; HR verlangt Betriebsratsbeteiligung.

Die kritischsten offenen Punkte sind Lieferanten-Fernwartung, fehlende Restore-Tests, Zertifikatsabläufe in Java-Signierprozessen und unklare Screenshot-Regeln in Supportkanälen.

BSIG 2025 und NIS-2 live prüfen

BSI-Grundschutz-Schutzbedarf sauber dokumentieren

Slack/MDM/AirTags nicht getrennt, sondern als Daten- und Securityverbund betrachten

Datei: 14-policy-entwurf-screenshots-und-chat.docx

Policy-Entwurf: Screenshots und Chatkanäle

Screenshots aus Logs, Tickets und Kundenumgebungen dürfen nicht ungeprüft in offene Chatkanäle gestellt werden. Tokens, personenbezogene Daten, Gesundheitsdaten, Kundengeheimnisse und Quellcode werden vor Weitergabe geschwärzt oder in freigegebene Systeme verschoben.

Externe Channels benötigen einen verantwortlichen Owner, Ablaufdatum und Datenklasse.

Keine privaten Messenger für Kundenstörungen

Sicherheitsvorfälle nur im Krisenkanal

Legal Hold wird gesondert angeordnet

Datei: 23-entscheidungsvorlage-kurzfassung.docx

Kurzfassung Entscheidungsvorlage

Lahnwerke Maschinenbau AG rollt Slack aus, verfolgt LKW-Werkzeugcontainer mit AirTags, betreibt MDM auf Firmenhandys und hat nach einem Lieferanten-VPN-Vorfall Zweifel an NIS-2-/BSI-Reife.

Die Entscheidung sollte nicht auf Grundlage einzelner Schlagworte getroffen werden. Maßgeblich sind Nachweisbarkeit, Zuständigkeit, Frist und ein realistischer nächster Schritt.

Rote Punkte zuerst behandeln

Quellen live prüfen

Offene Tatsachen ausdrücklich offen lassen

Bildanlagen und Screenshots

Datei: 12-whatsapp-it-legal.jpg

IT / Legal 26.05.

IT

Wenn wir Slack morgen nicht freigeben, ziehen Vertrieb und Service weiter über private WhatsApp-Gruppen.

Legal

Dann lieber sauber schnell: Datenklassen, externe Gäste, Screenshot-Regel, Betriebsrat, Adminrechte.

IT

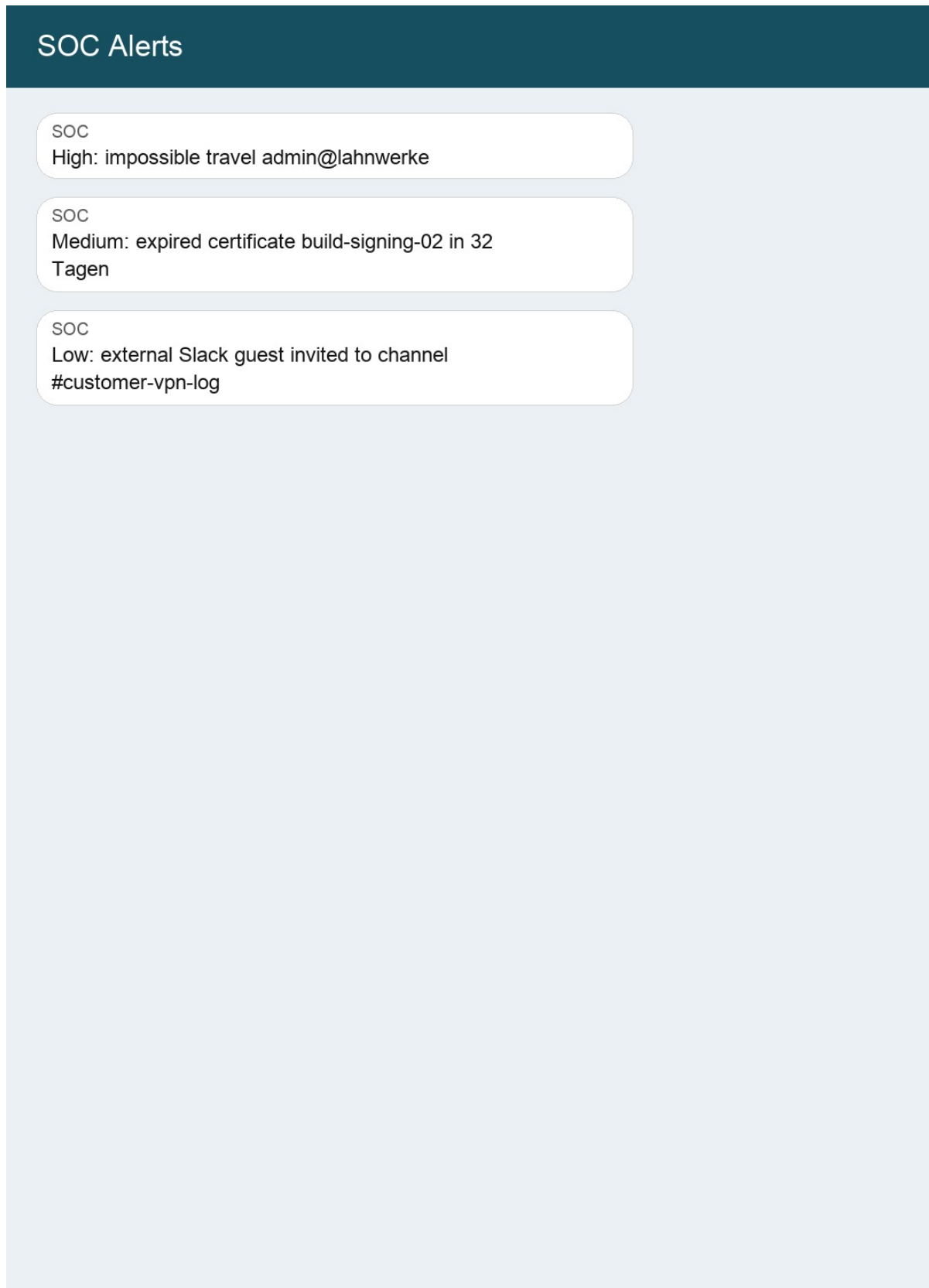
AirTags an LKWs hängen schon an acht Fahrzeugen. Logistik sagt Diebstahlschutz.

Legal

Dann muss das in dieselbe Vorlage. Zweckbindung, Beschäftigtendaten, Zugriff, Löschung.

Bilddatei: 12-whatsapp-it-legal.jpg

Datei: 13-screenshot-siem-alerts.jpg



Bilddatei: 13-screenshot-siem-alerts.jpg

PDF-Anhang: 06-nis2-betroffenheitsvermerk.pdf

Datei: 06-nis2-betroffenheitsvermerk.pdf

Vorläufiger Betroffenheitsvermerk

Die Gesellschaft liefert Ersatzteile an Energie- und Verkehrskunden, betreibt aber zugleich eigene digitale Dienste für Fernwartung. Die Einordnung hängt davon ab, welche Dienste tatsächlich am Markt erbracht werden und welche Konzernschwellen erreicht sind.

Nicht ausreichend ist die Aussage, man sei ISO-zertifiziert. Entscheidend ist, welche Pflichten nach NIS-2/BSIG ausgelöst werden, wer registriert, wer meldet und welche technischen Maßnahmen tatsächlich getestet sind.

Punkt	Sachstand	Risiko
Sektor	Produktion plus digitale Fernwartung	Einordnung offen
Größe	ca. 780 MA Konzernverbund	Schwelle wahrscheinlich
Meldung	Incidentprozess nicht getestet	rot

PDF-Anhang: 07-slack-cloud-security-memo.pdf

Datei: 07-slack-cloud-security-memo.pdf

Slack-Rollout: Security- und Legal-Prüfung

Fachbereiche möchten Slack mit externen Channels für Großkunden nutzen. Die Richtlinie muss regeln, welche Datenklassen dort erscheinen dürfen, wie Screenshots behandelt werden und wer externe Gäste freigibt.

Technisch fehlen noch DLP-Regeln, Aufbewahrungskonzept, Admin-Rollen, Exportprozess und Abgleich mit Betriebsrat und Datenschutz.

Thema	Entscheidung
Externe Gäste	nur mit Owner und Ablaufdatum
Screenshots	keine Tokens, keine Personaldaten, keine ungeprüften Logs
Retention	Legal Hold mit DSGVO-Abwägung

PDF-Anhang: 11-backup-restore-protokoll.pdf

Datei: 11-backup-restore-protokoll.pdf

Restore-Test 14.05.2026

Der Restore des Fileservers gelang nach 6 Stunden. Der ERP-Test wurde abgebrochen, weil die AD-Recovery-Dokumentation nicht auffindbar war. Der Dienstleister hat zugesagt, eine zweite Übung vorzuschlagen.

Die Geschäftsleitung soll nicht nur Backup-Erfolg melden, sondern offen dokumentieren, dass ein vollständiger Wiederanlauf noch nicht bewiesen ist.

System	Ergebnis	Lücke
Fileserver	OK	RPO 12h
ERP	abgebrochen	AD-Recovery fehlt
Telefonie	nicht getestet	Fallback unklar

PDF-Anhang: 17-cloud-provider-c5-luecken.pdf

Datei: 17-cloud-provider-c5-luecken.pdf

Cloud-Provider-Prüfung

Der Provider verweist auf ein C5-Testat, liefert aber nur eine Zusammenfassung. Die Subdienstleisterliste enthält Supportzugriffe aus mehreren Regionen. Der Exit-Test wurde noch nie durchgeführt.

Für die Vorstandsvorlage ist zu trennen: Vertraglich zugesagt, technisch implementiert, auditiert, ungeprüft.

Kontrolle	Nachweis	Bewertung
C5	Executive Summary	gelb
Subprozessoren	Liste 2025	gelb
Exit	kein Test	rot

PDF-Anhang: 20-board-briefing-draft.pdf

Datei: 20-board-briefing-draft.pdf

Board-Briefing Arbeitsstand

Die Gesellschaft sollte den Rollout nicht stoppen, aber an rote Mindestbedingungen knüpfen: externe Slack-Channels nur mit Owner, AirTag-Zugriff nur für Logistik-Leitung und Betriebsvereinbarung, Fernwartung nur mit MFA und Session Recording, Restore-Test binnen vier Wochen.

Nächster Beschluss: Budget für PKI/HSM, SOC Use Cases und Lieferantenkontrolle freigeben.

Beschluss	Frist	Owner
Slack Controlled Rollout	14 Tage	CISO
AirTag BV	30 Tage	HR
Restore-Test	4 Wochen	IT Betrieb

PDF-Anhang: 24-arbeitsstand-fuer-besprechung.pdf

Datei: 24-arbeitsstand-fuer-besprechung.pdf

Besprechungsunterlage

Diese Unterlage bündelt den Arbeitsstand für die nächste Besprechung. Sie ersetzt keine abschließende Prüfung, sondern sortiert Unterlagen, Entscheidungen und Lücken.

Bitte in der Besprechung zuerst klären, welche Entscheidung wirklich heute gebraucht wird.

TOP	Frage
1	Was muss entschieden werden?
2	Welche Quelle fehlt?
3	Wer liefert Nachweise?
4	Welcher Text wird benötigt?